



Thread Modelling

Penerapan Keamanan Informasi pada Platform Manajemen Lowongan Magang Berbasis Web
(CareerFlow)

Kelompok 5 :

Hanifah Syahidah	G6401231067	K2
Khalisa Rana Putri	G6401231141	K2
Aliya Shahira	G6401231116	K2

I. Pendahuluan

A. Latar Belakang

Dokumen ini menjelaskan hasil analisis ancaman (threat modelling) terhadap sistem CareerFlow menggunakan kerangka kerja STRIDE. Analisis dilakukan untuk mengidentifikasi potensi ancaman keamanan, aset yang berisiko, serta mitigasi yang diterapkan atau direncanakan pada arsitektur sistem.

STRIDE adalah akronim dari: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, dan Elevation of Privilege.

B. Aset yang Dilindungi

Kategori	Aset	Keterangan
Data Pengguna	Email, Password (hashed), NIM, Nama, Program Studi	Data identitas mahasiswa dan admin yang tersimpan di database.
Data Jaringan (PII)	ip_address_encrypted	Jejak digital IP pengguna pada tabel audit_logs yang dilindungi secara kriptografis.

Kategori	Aset	Keterangan
Token Autentikasi	JWT Access Token	Token stateless berisi identity dan role untuk mengakses endpoint terproteksi.
Data Lowongan	LowonganMagang records	Data lowongan magang komprehensif yang dikelola oleh administrator platform.
Data Lamaran	Lamaran records, dokumen CV	Riwayat pelamaran kerja serta dokumen fisik CV milik mahasiswa.
OTP Code	Kode OTP 6 digit	Kode sementara di tabel otp_code untuk verifikasi pendaftaran dan reset password.
Secret Key	JWT_SECRET_KEY, AES_SECRET_KEY	Kunci rahasia di file .env untuk penandatanganan token dan enkripsi data.

II. Analisis Ancaman STRIDE

Tabel berikut merangkum seluruh ancaman yang diidentifikasi berdasarkan kerangka STRIDE, beserta tingkat kemungkinan (Likelihood), dampak (Impact), dan mitigasi konkrit yang diterapkan atau direncanakan.

Skala Keamanan: L = Low, M = Medium, H = High

ID	Kategori	Ancaman	Aset Terdampak	Lik e.	Impa ct	Mitigasi
S-01	Spoofing	Penyerang berpura-pura sebagai pengguna sah menggunakan kredensial curian.	Data login, JWT Token	M	H	JWT memiliki signature unik. Password diamankan via Werkzeug PBKDF2-SHA256. OTP membatasi akses tanpa verifikasi email.
S-02	Spoofing	Penyerang membuat akun admin palsu untuk mendapatkan hak akses khusus.	Endpoint admin, data lowongan	L	H	Role admin hanya di-insert manual di database. Tidak ada endpoint publik untuk registrasi akun admin.
S-03	Spoofing	Token JWT dipalsukan atau dimanipulasi di sisi client untuk bypass session.	Semua endpoint JWT-protected	L	H	JWT ditandatangani dengan JWT_SECRET_KEY dari .env. Verifikasi signature divalidasi setiap request.
T-01	Tampering	Manipulasi data lowongan secara langsung melalui intercept request HTTP.	LowonganMagang records	M	H	Endpoint CRUD admin dilindungi @jwt_required() + pengecekan role. Validasi input via validator.py.
T-02	Tampering	Mahasiswa memanipulasi request untuk mengubah status	Lamaran records	M	M	Endpoint update status memverifikasi identitas JWT dan memastikan NIM mahasiswa sesuai pemilik lamaran.

ID	Kategori	Ancaman	Aset Terdampak	Lik e.	Impa ct	Mitigasi
		lamarannya secara ilegal.				
T-03	Tampering	Manipulasi payload JWT untuk menaikkan role pengguna dari mahasiswa ke admin.	Semua endpoint terproteksi	L	H	JWT dienkapsulasi dengan HMAC signature. Modifikasi payload sekecil apapun otomatis merusak validitas token.
R-01	Repudiation	Admin menyangkal telah menambah, mengedit, atau menghapus data lowongan krusial.	LowonganMag ang records	M	M	Eksisting: Audit Logging (AuthService.log_activity()) mencatat aksi 5W1H. Minggu 9-10: Tanda tangan digital RSA/ECDSA.
R-02	Repudiation	Mahasiswa menyangkal telah mengirimkan dokumen lamaran tertentu.	Lamaran records	L	M	Setiap transaksi mengunci tanggalApply dan nimMahasiswa. Data terikat ke akun terverifikasi JWT.
I-01	Info Disclosure	Kredensial password bocor dalam bentuk plaintext akibat	Password mahasiswa & admin	M	H	SQLAlchemy ORM (prepared statements). Password tersimpan sebagai hash dari generate_password_hash.

ID	Kategori	Ancaman	Aset Terdampak	Lik e.	Impa ct	Mitigasi
		serangan SQL Injection.				
I-02	Info Disclosure	Kode OTP dicegat atau ditebak di jaringan untuk pengambilan akun.	OTP Code, akun mahasiswa	M	H	OTP 6 digit acak, masa kadaluarsa 10 menit, hangus setelah satu kali pakai (is_used flag).
I-03	Info Disclosure	Kunci rahasia kriptografi terekspos karena tidak sengaja terpush ke repository publik.	Seluruh sistem autentikasi	L	H	JWT_SECRET_KEY dan AES_SECRET_KEY diisolasi di .env, wajib didaftarkan di .gitignore.
I-04	Info Disclosure	Pihak luar mengintip data privasi jaringan atau mahasiswa mengintip lamaran pelamar lain.	Lamaran records, IP Address	M	M	Enkripsi AES-256 Fernet pada kolom ip_address_encrypted (Data at Rest). Service layer memvalidasi NIM.
D-01	DoS	Serangan spam request ke endpoint OTP untuk membanjiri resource mail server.	OTP table, email server	H	M	OTP lama dinonaktifkan saat request baru masuk. Minggu 11-12: Flask-Limiter.

ID	Kategori	Ancaman	Aset Terdampak	Lik e.	Impa ct	Mitigasi
D - 0 2	DoS	Spam request brute-force login untuk melumpuhkan performa server API.	Server, Database	H	M	Docker Containers dengan restart: always. Minggu 11-12: Flask-Limiter.
D - 0 3	DoS	Mengunggah dokumen CV berukuran raksasa untuk menghabiskan storage server.	Server storage, database	M	M	Minggu 11-12: Pembatasan max content length dan whitelist tipe file di API lamaran.
E - 0 1	EoP	Mahasiswa mencoba mengeksekusi endpoint khusus milik administrator platform.	Endpoint /admin/*	M	H	RBAC: klaim role dari JWT; request non-admin diblokir dengan HTTP 403 Forbidden.
E - 0 2	EoP	Pengguna anonim tanpa login mencoba menembak API data internal platform.	Modul internal & CRUD	M	H	Dekorator @jwt_required() di seluruh rute sensitif. Request tanpa token diblokir via HTTP 401.
E - 0 3	EoP	Mahasiswa memanipulasi ID lamaran untuk mengubah	Lamaran records	M	M	Service layer memvalidasi kesesuaian NIM dari JWT dengan data lamaran sebelum

I D	Kategori	Ancaman	Aset Terdampak	Lik e.	Impa ct	Mitigasi
		status lamaran milik orang lain.				memproses pembaruan.

III. Ringkasan Kontrol Mitigasi

Komponen Kontrol Keamanan	Implementasi Teknis	Status	Referensi Kode / Dokumen
Password Hashing & Salting	Werkzeug PBKDF2-SHA256 dengan salt acak otomatis.	Sudah Diimplementasi	auth_routes.py / AuthController
JWT Authentication Layer	Flask-JWT-Extended dengan validasi signature via environment variable.	Sudah Diimplementasi	magang_routes.py / @jwt_required()
Role-Based Access Control	Pengecekan klaim role ('admin'/'mahasiswa') pada controller layer.	Sudah Diimplementasi	controllers/magang_controller.py
OTP Single-Use Vault	Verifikasi 6 digit acak, masa berlaku 10 menit, flag is_used.	Sudah Diimplementasi	Modul Autentikasi / Tabel otp_code
Data at Rest Protection	Enkripsi Simetris AES-256 Fernet pada kolom ip_address_encrypted.	Sudah Diimplementasi	models.py / services/auth_service.py
Secure Logging (Accounting)	Pencatatan log audit insiden 5W1H (Sukses/Gagal/Akses Ilegal).	Sudah Diimplementasi	services/auth_service.py => log_activity()
Secrets Isolation	Penggunaan .env eksternal yang di-exclude oleh .gitignore.	Sudah Diimplementasi	Konfigurasi Root Proyek .gitignore

Komponen Kontrol Keamanan	Implementasi Teknis	Status	Referensi Kode / Dokumen
Asymmetric Digital Signature	Penandatanganan CRUD Admin dengan Key-Pair RSA/ECDSA.	Direncanakan (Minggu 9-10)	03_Source_Code/digital_signature/
API Rate Limiting	Pemasangan Flask-Limiter untuk mencegah DoS dan brute force.	Direncanakan (Minggu 11-12)	Rencana Pengembangan Modul Utama
File Upload Filter	Pembatasan ukuran maksimum payload dan filter ekstensi berkas CV.	Direncanakan (Minggu 11-12)	Rencana Pengembangan Modul Lamaran

